COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.5 · Segmentation & Access Control

Mestre CyberSec · **Aula 2.5 — Segmentation & Access Control** (6:06) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Isolamento network: VLAN / sub-rede / DMZ (screened subnet) — se um setor compromete, não contamina o resto. ACL (Access Control List) = o QUE pode entrar no recurso. Allowlist (default DENY — só o conhecido passa) > denylist (default ALLOW — bloqueio o conhecido). Microsegmentaç

💡 Highlights que a prova CompTIA cobra

- DMZ: zona entre internet e rede interna — o público mora lá
- Allowlist (deny-by-default) é MAIS SEGURA que denylist
- Microsegmentação: cada carga isolada — Zero Trust aplicado

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'default deny, permit only known' = allowlist
- 'zone between internet and internal network' = DMZ/screened subnet

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.5 — Segmentation & Access Control)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Rede Local Virtual (VLAN)
Segmentação lógica de uma rede física que agrupa dispositivos em domínios de broadcast separados, independentemente da localização física, para isolar tráfego e reduzir exposição a ataques.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'segment a network logically without new hardware' or 'separate broadcast domains' → VLAN. Do not confuse with subnetting (Layer 3); VLANs operate at Layer 2.*

• Zona Desmilitarizada (DMZ)
Sub-rede protegida ou rede de perímetro posicionada entre uma rede não confiável (Internet) e uma rede interna confiável, hospedando serviços públicos como servidores web e e-mail para proteger ativos internos.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'zone between the Internet and the internal network' or 'place to put public-facing servers' → DMZ/screened subnet. CompTIA often uses 'screened subnet' as a synonym.*

• Lista de Controle de Acesso (ACL)
Conjunto de regras aplicadas a interfaces de rede ou recursos que filtram tráfego ou acesso com base em IP, porta, protocolo ou identidade do usuário, definindo o que é permitido ou negado.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'rules that define what traffic is permitted' or 'rule-based filtering on a router/firewall' → ACL. Know the difference: ACL = WHAT can enter; firewall often enforces broader rules including stateful inspection.*

• Lista de Permissão (Negação Padrão) (N/A)
Abordagem de segurança na qual apenas itens explicitamente aprovados (IPs, aplicações, usuários) recebem acesso, e todo o resto é implicitamente negado por padrão.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'default deny, permit only known' or 'most secure access policy' → Allowlist. CompTIA considers allowlist MORE secure than denylist because it blocks unknown threats proactively.*

• Lista de Bloqueio (Permissão Padrão) (N/A)
Abordagem de segurança na qual tudo é permitido por padrão e apenas itens especificamente identificados são bloqueados, comumente usada para IPs ou aplicações maliciosas conhecidas.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'block only known bad traffic' → Denylist. Less secure because zero-day/new threats pass through; CompTIA recommends allowlist for high-security environments.*

• Microsegmentação (N/A)

Arquitetura de segurança que divide uma rede em zonas muito pequenas e isoladas (frequentemente por carga de trabalho, aplicação ou dispositivo) para aplicar políticas granulares e limitar movimento lateral.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'isolate each workload individually' or 'apply Zero Trust at the workload level' → Microsegmentation. Key distinction: traditional segmentation uses broad zones; microsegmentation uses tiny per-asset boundaries.*

• Confiança Zero (N/A)

Modelo de segurança que assume nenhuma confiança implícita para qualquer usuário, dispositivo ou localização de rede, exigindo verificação contínua e acesso de menor privilégio para cada requisição.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'never trust, always verify' or 'no implicit trust based on network location' → Zero Trust. Pairs directly with microsegmentation and applies to internal AND external requests.*

• Sub-rede (N/A)

Subdivisão lógica de uma rede IP que separa hosts em grupos menores usando máscaras de sub-rede, permitindo isolamento de tráfego e roteamento eficiente.

⚠️ ***Armadilha CompTIA:*** *Trigger: 'segment a network at Layer 3' or 'divide network using subnet masks' → Subnet. Differentiate from VLAN (Layer 2): subnetting uses IP addressing; VLANs use switch ports/tags.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Redução da Superfície de Ataque e Desativação de Portas/Serviços

🏠 **Analogia Intuitiva:** Uma casa com 20 janelas de vidro, 6 portas externas e um alçapão no telhado é muito mais difícil de defender contra ladrões do que uma casa com apenas uma porta blindada e nenhuma janela acessível da rua. O hardening de um servidor é como murar as 19 janelas desnecessárias, trancar o alçapão e manter apenas a única porta necessária para o negócio. Se você não usa Telnet (porta 23) ou FTP (porta 21), desligue o serviço; uma porta fechada não pode ser invadida.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais de fábrica vêm com inúmeros serviços auxiliares ativados para facilitar a compatibilidade com usuários domésticos. Cada serviço ativo roda código que pode conter bugs, vulnerabilidades de estouro de buffer (buffer overflow) ou falhas de injeção exploráveis.

🛡️ **Visão do Auditor de GRC:** Executar varreduras periódicas com scanners de vulnerabilidade (Nessus/Nmap) para auditar portas abertas; validar que apenas os serviços constantes na Matriz de Portas Autorizadas do plano diretor de segurança estejam em execução.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'system administrator disables unused network services and closes unnecessary ports to minimize potential entry points'. Resposta: Attack Surface Reduction / Hardening.

📌 CIS Benchmarks e Linhas de Base de Segurança (Security Baselines)

🏠 **Analogia Intuitiva:** É como a cartilha de vigilância sanitária ou as normas técnicas da ABNT/ISO para a cozinha de um grande hospital: não é uma questão de opinião do cozinheiro, é um checklist oficial de 300 itens minuciosos (temperatura exata do freezer, espessura da tábua de corte, tempo de lavagem das mãos) testado exaustivamente por especialistas para evitar que pacientes adoeçam. O CIS Benchmark é esse checklist de excelência técnica para configurar Windows, Linux, AWS ou Cisco de forma impenetrável.

🔍 **Causa Raiz / Por que foi criado:** Administradores configurando sistemas manualmente cometem erros humanos, adotam atalhos inseguros e geram inconsistências entre máquinas. Guias padronizados eliminam desvios de configuração (drift) e garantem proteção uniforme.

🛡️ **Visão do Auditor de GRC:** Fiscalizar o uso de ferramentas de conformidade automatizada (SCAP / OpenSCAP) que comparam as configurações dos servidores contra os perfis Level 1 e Level 2 do Center for Internet Security (CIS); exigir aprovação formal de exceções de risco para qualquer item não atendido.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'industry-recognized, consensus-based best practice configuration guidelines used worldwide to harden operating systems, applications, and cloud environments'. Resposta: CIS Benchmarks.

📌 Princípio do Menor Privilégio (Principle of Least Privilege - PoLP)

🏠 **Analogia Intuitiva:** Em um grande navio de cruzeiro, o passageiro tem um cartão magnético que só abre a porta da sua própria cabine. O mecânico do navio tem um cartão que abre a sala de máquinas, mas não abre a recepção nem o cofre do capitão. Ninguém anda pelo navio com a chave mestra de tudo o tempo todo. Se um passageiro perder seu cartão no convés, o ladrão só consegue entrar em uma cabine e não tem como afundar o navio.

🔍 **Causa Raiz / Por que foi criado:** Conceder privilégios administrativos para usuários comuns simplifica o suporte técnico (softwares não reclamam de permissão), mas se o usuário for vítima de phishing ou baixar um malware, o código malicioso executará com os mesmos privilégios do usuário e dominará a máquina inteira.

🛡️ **Visão do Auditor de GRC:** Realizar revisões periódicas de acesso (Access Reviews); proibir contas de usuários comuns no grupo de Administradores Locais; exigir que administradores de sistemas utilizem contas separadas e dedicadas para tarefas administrativas com PAM (Privileged Access Management).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'users and processes are granted only the minimum permissions necessary to perform their required job duties'. Resposta: Principle of Least Privilege (PoLP).

📌 Desativação e Renomeação de Contas Padrão (Default Accounts & Passwords)

🏠 **Analogia Intuitiva:** Comprar um roteador Wi-Fi ou câmera de segurança e deixar o usuário como 'admin' e a senha como 'admin' ou '123456' é como comprar uma casa nova e deixar na porta da frente a chave de plástico amarela que a construtora usou na obra com um bilhete: 'Porta aberta para quem quiser entrar!'. Todo ladrão na rua conhece a senha de fábrica de todos os aparelhos do mercado.

🔍 **Causa Raiz / Por que foi criado:** Fabricantes programam credenciais padrão idênticas de fábrica para permitir o primeiro acesso pelo técnico. Botnets automatizadas (como a Mirai) varrem a internet inteira 24 horas por dia testando essas listas de senhas padrão em dispositivos recém-ligados.

🛡️ **Visão do Auditor de GRC:** Estabelecer procedimento operacional padrão (SOP) de comissionamento de ativos exigindo a troca imediata de senhas padrão, renomeação de contas como 'Administrator' e desativação da conta 'Guest' antes de qualquer conexão à rede de produção.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'first step a network administrator must perform when deploying a new network appliance, router, or server'. Resposta: Change default passwords / Disable default accounts.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Desativar portas de rede e serviços desnecessários para fechar portas de entrada a invasores	**Redução da Superfície de Ataque (Attack Surface Reduction)**
Guias consensuais da indústria internacional para endurecer sistemas operacionais e servidores	**CIS Benchmarks**
Garantir que colaboradores e processos tenham somente as permissões mínimas essenciais para seu trabalho	**Princípio do Menor Privilégio (Principle of Least Privilege)**
Ação inicial obrigatória na instalação de qualquer novo roteador, switch ou dispositivo IoT corporativo	**Alteração de Credenciais Padrão (Change Default Passwords)**
Substituição de protocolos em texto claro (Telnet, HTTP) por versões criptografadas seguras (SSH, HTTPS)	**Endurecimento de Protocolos (Protocol Hardening - SSH/HTTPS)**
Conta de sistema operacional padrão que deve ser mantida desativada por política de segurança	**Conta de Convidado (Guest Account)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa tem as equipes de Finanças e Engenharia conectadas ao mesmo switch físico de Camada 2. A equipe de segurança quer impedir tráfego de broadcast e movimento lateral casual entre as duas equipes, mantendo ainda tráfego controlado pelo firewall. Qual abordagem de segmentação deve ser implementada?

A) Criar VLANs separadas para Finanças e Engenharia e rotear o tráfego entre VLANs pelo firewall.

B) Colocar os servidores de Finanças em uma DMZ e deixar Engenharia na LAN interna.

C) Usar uma única sub-rede com uma denylist que bloqueia endereços IP de atacantes conhecidos.

D) Habilitar microsegmentação apenas no servidor de banco de dados de Finanças.

QUESTÃO 2 · CENÁRIO DE EXAME

Uma organização hospeda um servidor web de e-commerce público que deve receber conexões HTTPS da internet. O banco de dados interno não deve ser diretamente acessível pela internet, mas o servidor web precisa de acesso limitado ao banco. Onde o servidor web deve ser colocado?

A) Em uma VLAN interna com o servidor de banco de dados e um firewall baseado em host.

B) Em uma sub-rede screenada/DMZ com regras de firewall permitindo HTTPS de entrada e somente o tráfego necessário ao banco de dados na saída.

C) Na rede Wi-Fi de visitantes com NAT para o banco de dados.

D) Na mesma sub-rede das estações de trabalho dos funcionários para simplificar a administração.

QUESTÃO 3 · CENÁRIO DE EXAME

Administradores precisam gerenciar um jump server. Apenas dois endereços IP conhecidos de administradores devem poder iniciar sessões SSH, e qualquer outra origem deve ser rejeitada. Qual abordagem de controle de acesso deve ser configurada?

A) Uma denylist com padrão allow que bloqueia IPs conhecidos de administradores maliciosos.

B) Uma allowlist com padrão deny que permite apenas os dois IPs de administradores.

C) Uma DMZ que coloca o jump server entre dois firewalls.

D) Uma VLAN que atribui o jump server ao domínio de broadcast do banco de dados.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa quer que os funcionários naveguem na maioria dos sites da internet, mas precisa bloquear acesso a uma lista conhecida de domínios de phishing. A equipe de segurança não quer aprovar cada site legítimo. Qual abordagem de filtragem melhor atende a esse requisito?

A) Allowlist com padrão deny.

B) Denylist com padrão allow.

C) DMZ com padrão deny.

D) Microsegmentação com padrão deny.

QUESTÃO 5 · CENÁRIO DE EXAME

Um data center tem muitas máquinas virtuais em uma única VLAN grande. Após uma VM ser comprometida, o atacante se move lateralmente para outras VMs usando tráfego east-west permitido. Qual controle melhor limita esse tipo de movimento entre cargas de trabalho individuais?

A) Um único firewall de perímetro na borda da internet.

B) Políticas de microsegmentação aplicadas entre cargas de trabalho individuais.

C) Uma DMZ que contém todas as máquinas virtuais internas.

D) Uma denylist de hashes de malware conhecidos no hypervisor.

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa quer que funcionários internos passem pelas mesmas verificações de identidade e autorização que usuários remotos antes de acessar cada aplicação interna. A localização na rede não deve mais implicar confiança. Qual modelo de segurança deve ser adotado?

A) Zero Trust.

B) Sub-rede screenada.

C) Trunking de VLAN.

D) Filtragem baseada em denylist.

QUESTÃO 7 · CENÁRIO DE EXAME

Um engenheiro de rede precisa dividir 172.16.10.0/24 em quatro redes IP separadas para departamentos diferentes. Cada rede deve ser roteável e controlada por regras de firewall entre departamentos. Qual conceito está sendo usado?

A) Subnetting.

B) Posicionamento em DMZ.

C) Allowlisting.

D) Microsegmentação.

QUESTÃO 8 · CENÁRIO DE EXAME

Um roteador conecta uma rede pública a um segmento de servidor web. O administrador precisa que o roteador permita TCP 443 para o servidor web e rejeite todo o restante do tráfego destinado a esse servidor. O que deve ser configurado no roteador?

A) Uma ACL aplicada à interface relevante.

B) Uma VLAN atribuída à porta do switch do servidor web.

C) Uma sub-rede screenada sem regras de firewall.

D) Uma denylist para consultas DNS.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma regra de firewall para uma aplicação interna de RH atualmente permite qualquer origem alcançá-la e depois nega uma lista de endereços IP maliciosos conhecidos. Um auditor diz que isso é permissivo demais. Qual mudança melhor alinha a regra ao menor privilégio?

A) Substituir a regra por uma allowlist que permite apenas a sub-rede de RH e nega todas as outras origens.

B) Adicionar mais endereços IP maliciosos conhecidos à lista de negação existente.

C) Mover a aplicação de RH para uma DMZ e permitir todas as sub-redes internas.

D) Criar uma VLAN única para todos os departamentos para simplificar a regra de firewall.

QUESTÃO 10 · CENÁRIO DE EXAME

Terceirizados usam uma rede Wi-Fi de visitantes e precisam de acesso à internet, mas não devem alcançar servidores de arquivos internos ou sub-redes de funcionários. Qual projeto melhor impõe esse requisito?

A) Colocar o Wi-Fi de visitantes em uma VLAN/sub-rede separada e aplicar ACLs que negam acesso a faixas de endereços internos.

B) Colocar o Wi-Fi de visitantes na DMZ e permitir todo o tráfego para servidores de arquivos internos.

C) Usar uma denylist de dispositivos de terceirizados conhecidos na LAN interna.

D) Habilitar microsegmentação apenas nos servidores de arquivos internos, deixando o Wi-Fi de visitantes na VLAN interna.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Criar VLANs separadas para Finanças e Engenharia e rotear o tráfego entre VLANs pelo firewall.

VLANs separadas criam domínios de broadcast distintos de Camada 2 no mesmo switch físico e podem forçar o tráfego entre VLANs a passar por roteador ou firewall. Uma DMZ é para serviços expostos, uma denylist não isola departamentos internos, e microsegmentação em um único servidor não segmenta as equipes.

Questão 2: Alternativa B — Em uma sub-rede screenada/DMZ com regras de firewall permitindo HTTPS de entrada e somente o tráfego necessário ao banco de dados na saída.

Uma sub-rede screenada/DMZ isola serviços voltados à internet da rede interna. Regras de firewall podem permitir HTTPS de entrada e restringir a saída apenas ao serviço de banco de dados necessário. VLAN interna com o BD aumenta a exposição, Wi-Fi de visitantes é inadequado, e a sub-rede de estações aumenta o movimento lateral.

Questão 3: Alternativa B — Uma allowlist com padrão deny que permite apenas os dois IPs de administradores.

Uma allowlist com padrão deny permite somente origens explicitamente aprovadas e rejeita todas as outras, exatamente como o requisito. Uma denylist com padrão allow deixaria origens desconhecidas tentarem acesso, a menos que listadas como más. DMZ e VLAN são conceitos de segmentação, não autorização SSH por origem.

Questão 4: Alternativa B — Denylist com padrão allow.

Uma denylist com padrão allow bloqueia domínios maliciosos conhecidos e permite todo o resto, adequando-se a uma política ampla de navegação. Uma allowlist exigiria aprovar cada site permitido. DMZ e microsegmentação são controles de segmentação, não filtragem de sites por categoria.

Questão 5: Alternativa B — Políticas de microsegmentação aplicadas entre cargas de trabalho individuais.

A microsegmentação aplica políticas granulares por carga de trabalho e pode bloquear tráfego east-west desnecessário mesmo dentro da mesma VLAN. Um firewall de perímetro não controla bem o tráfego interno VM-a-VM, uma DMZ é para serviços expostos, e denylists de hash de arquivo não impedem movimento lateral de rede.

Questão 6: Alternativa A — Zero Trust.

Zero Trust remove a confiança implícita baseada na localização na rede e exige verificação contínua e autorização de menor privilégio para cada requisição. Sub-redes screenadas e VLANs são ferramentas de segmentação, e filtragem por denylist bloqueia apenas itens maliciosos conhecidos.

Questão 7: Alternativa A — Subnetting.

Subnetting divide uma rede IP maior em redes IP lógicas menores que podem ser roteadas e filtradas entre si. Uma DMZ é um segmento screenado específico para serviços expostos, allowlisting é uma abordagem de controle de acesso, e microsegmentação geralmente aplica políticas no nível da carga de trabalho.

Questão 8: Alternativa A — Uma ACL aplicada à interface relevante.

Uma ACL é um conjunto de regras de permitir ou negar avaliadas contra o tráfego, frequentemente em interfaces de roteador ou firewall. Ela pode permitir TCP 443 e negar todo o restante do tráfego ao servidor. VLANs fornecem segmentação de Camada 2, mas não regras detalhadas de permitir/negar, uma sub-rede screenada ainda precisa de regras, e denylist de DNS não controla tráfego web.

Questão 9: Alternativa A — Substituir a regra por uma allowlist que permite apenas a sub-rede de RH e nega todas as outras origens.

A regra atual usa padrão allow com denylist. O menor privilégio exige uma allowlist com padrão deny: somente a sub-rede de RH deve ser permitida, e todas as outras origens negadas. Adicionar IPs maliciosos deixa origens desconhecidas permitidas, DMZ não corrige acesso amplo demais, e uma VLAN única aumenta a exposição.

Questão 10: Alternativa A — Colocar o Wi-Fi de visitantes em uma VLAN/sub-rede separada e aplicar ACLs que negam acesso a faixas de endereços internos.

Uma VLAN/sub-rede separada para visitantes isola terceirizados nas Camadas 2/3, e ACLs podem negar tráfego para faixas internas RFC1918 enquanto permitem acesso à internet. DMZ com acesso interno viola o requisito, uma denylist de dispositivos é fraca, e deixar o Wi-Fi de visitantes na VLAN interna aumenta o risco de movimento lateral.